

BreachScope 침해사고 초동분석 보고서

Executive handoff report / 고객 제출용 요약

Risk Score	탐지 현황	분석 범위
100	54 findings critical level	48 events 12 hosts / 35 techniques

생성 시각	2026-09-15T16:03:05Z
PDF 폰트	NanumGothic.ttf
분석 성격	규칙 기반 초동분석 - 탐지 결과는 원본 로그/업무 맥락으로 재검증 필요
기밀 등급	Confidential / 내부 공유 또는 고객 제출 전 검토 권장

1. 경영진 요약

- 총 54건의 의심 이벤트가 탐지되었고, 주요 영향 호스트는 WS-301입니다.
- 가장 많이 관측된 ATT&CK; 기법은 T1059.001(Command and Scripting Interpreter: PowerShell)입니다.
- high/critical 등급 탐지가 22건 있어 우선 확인이 필요합니다.

2. 우선 조치 권고

- PowerShell 실행 주체, 전체 명령줄, 스크립트 블록 로그를 확인하고 승인된 관리 작업인지 검증합니다.
- 탐지된 URL/IP 접속 이력과 다운로드 파일 해시를 확인하고, 프록시·방화벽 로그와 대조합니다.
- LSASS 접근 흔적이 있으면 해당 호스트를 격리하고 계정 비밀번호·토큰 탈취 가능성을 우선 조사합니다.
- 이벤트 로그 삭제 정황은 은폐 행위일 수 있으므로 중앙 로그, EDR, 백업 로그에서 동일 시간대를 복원합니다.
- 예약 작업과 Run 키를 확인하여 지속성 등록 여부를 점검하고 승인되지 않은 항목은 비활성화합니다.
- 동일 사용자·동일 호스트 기준으로 전후 30분의 프로세스 생성, 네트워크 연결, 인증 이벤트를 묶어 타임라인을 재구성합니다.

3. 우선 확인 탐지 Top 5

등급	룰	MITRE	호스트	시간
critical	Ransomware Shadow Copy Removal Variant	T1490	FS-01	2026-01-15T09:24:00+00:00
critical	Ransomware Shadow Copy Removal Variant	T1490	FS-01	2026-01-15T09:22:00+00:00
critical	NTDS.dit Dump Attempt	T1003.003	SRV-DC01	2026-01-15T09:16:00+00:00
high	Microsoft Defender Disable Attempt	T1562.001	WS-601	2026-01-15T10:36:00+00:00
high	Windows Audit Policy Disable	T1562.002	WS-601	2026-01-15T10:32:00+00:00

4. 호스트별 위험도

호스트	점수	레벨	탐지	주요 기법
WS-301	100/100	critical	8	T1018, T1057, T1087.001, T1087.002
WS-401	100/100	critical	7	T1127.001, T1202, T1218.003, T1218.004
WS-101	100/100	critical	7	T1059.001, T1105
FS-01	100/100	critical	7	T1070.001, T1490, T1562.001
SRV-DC01	100/100	critical	5	T1003.001, T1003.002, T1003.003
FS-02	100/100	critical	4	T1105, T1560.001, T1567.002
WS-601	100/100	critical	4	T1562.001, T1562.002, T1562.004
WS-701	64/100	high	4	T1113, T1115, T1555.003, T1560.001

5. 사고 타임라인

시간	호스트	사용자	등급	전술	룰
2026-01-15T09:00:00+00:00	WS-101	CORP\alice	medium	Execution	PowerShell Bypass/Hidden Flags
2026-01-15T09:02:00+00:00	WS-101	CORP\alice	medium	Execution	Encoded PowerShell Command
2026-01-15T09:02:00+00:00	WS-101	CORP\alice	medium	Execution	EncodedCommand Generic (Safe)
2026-01-15T09:04:00+00:00	WS-101	CORP\alice	medium	Command and Control	Suspicious Web Download
2026-01-15T09:06:00+00:00	WS-101	CORP\alice	medium	Command and Control	Suspicious Web Download
2026-01-15T09:06:00+00:00	WS-101	CORP\alice	medium	Execution	PowerShell Invoke-Expression
2026-01-15T09:06:00+00:00	WS-101	CORP\alice	high	Execution	PowerShell DownloadString Execution
2026-01-15T09:10:00+00:00	SRV-DC01	CORP\svc-backup	high	Credential Access	LSASS Dump Attempt
2026-01-15T09:12:00+00:00	SRV-DC01	CORP\svc-backup	high	Credential Access	SAM SYSTEM Hive Save
2026-01-15T09:13:00+00:00	SRV-DC01	CORP\svc-backup	high	Credential Access	SAM SYSTEM Hive Save
2026-01-15T09:16:00+00:00	SRV-DC01	CORP\admin	critical	Credential Access	NTDS.dit Dump Attempt
2026-01-15T09:18:00+00:00	SRV-DC01	CORP\admin	high	Credential Access	WDigest Credential Exposure

6. ATT&CK: 전술 커버리지

전술	탐지	최고 등급	기법	호스트
Credential Access	6	critical	T1003.001, T1003.002, T1003.003, T1555.003	SRV-DC01, WS-701
Impact	5	critical	T1490	FS-01
Defense Evasion	13	high	T1070.001, T1127.001, T1202, T1218.003, T1218.004	FS-01, WS-401, WS-601

전술	탐지	최고 등급	기법	호스트
Execution	7	high	T1047, T1059.001, T1569.002	WS-101, WS-202, WS-203
Exfiltration	2	high	T1567.002	FS-02
Discovery	8	medium	T1018, T1057, T1087.001, T1087.002, T1135	WS-301
Persistence	5	medium	T1053.005, T1543.003, T1547.001	WS-203, WS-501
Collection	4	medium	T1113, T1115, T1560.001	FS-02, WS-701
Command and Control	3	medium	T1105	FS-02, WS-101
Lateral Movement	1	medium	T1021.006	WS-201

7. IOC 후보 요약

유형	개수
domain	1
ip	1
md5	1
path	27
url	7

8. 초동대응 체크리스트

- P1 - 영향 호스트 보존: 전원 차단보다 네트워크 격리와 증거 보존을 우선 검토합니다.
- P1 - 자격증명 보호 조치: LSASS 덤프 정황은 비밀번호/토큰 탈취 가능성을 의미합니다.
- P1 - 계정 사용 이력 확인: 동일 사용자 계정의 다른 호스트 로그인 여부가 확산 판단의 핵심입니다.
- P2 - IOC 차단 후보 검토: URL/IP/도메인을 프록시·방화벽·EDR에서 교차 확인합니다.
- P2 - 타임라인 확장: 최초 실행 전후 이벤트를 연결해야 원인과 범위를 줄일 수 있습니다.

9. 오탐 확인 질문

- 해당 명령을 실행한 사용자가 평소 해당 호스트에서 관리 작업을 수행하는 계정인가?
- 탐지 시각 전후 30분에 승인된 배포, 패치, 원격지원 작업이 있었는가?
- 부모 프로세스와 실행 경로가 조직 표준 도구 경로와 일치하는가?
- 탐지된 URL/도메인이 사내 업데이트 서버, 보안 솔루션, 공식 벤더 도메인인가?
- LSASS 접근이 백업/보안 제품의 정상 수집 동작인지 벤더 문서와 에이전트 로그로 확인했는가?
- 로그 삭제가 운영 절차에 따른 보관 정책 작업인지, 누가 승인했는지 확인했는가?

10. 증거 무결성 및 산출물

HTML/JSON/CSV/IOC/룰 카탈로그/Manifest/케이스 ZIP은 동일 케이스 산출물로 묶이며, Manifest에는 이벤트/탐지/파일 SHA-256 해시가 포함됩니다.

원본 증거 보존과 별도 검증을 위해 PDF는 요약 문서로 사용하고, 세부 증거는 JSON/CSV/Manifest를 함께 제출하십시오.